Company Profile: MediFlow AI

COMPLIANCE ASSESSMENT, Digital Health / Clinical Decision Support, Germany

MediFlow AI (Series A, headquartered in Berlin, Germany) builds an AI-powered symptom triage and care-coordination platform used by patients and clinics across the European Union and, more recently, the United States. The following is a summary of the company's current data and operational practices, prepared for compliance assessment.

1 PRODUCT AND DATA COLLECTED

MediFlow's mobile app collects each user's name, email, date of birth, self-reported symptoms, medication history, and continuous heart-rate data from connected wearables. At sign-up, users tick a single checkbox agreeing to the Terms of Service and Privacy Policy, which covers analytics, marketing, product improvement, and health processing in one combined statement.

Beyond what the triage feature needs today, the app also collects users' GPS location and phone contact lists "to support future social and location-based features that are still on the roadmap." This data is currently unused.

2 USERS AND SCALE

The platform has roughly 50,000 active users, the majority of whom are residents of the European Economic Area. Health data is stored indefinitely so that the AI models can be retrained on the full historical dataset; no automated deletion or retention cut-off is currently configured.

3 INFRASTRUCTURE AND SECURITY

All application traffic is served over HTTPS using TLS 1.3. The primary production database is hosted in AWS us-east-1 (Northern Virginia) for cost and latency reasons, and European user records are not segregated from this US deployment. Data stored in the database is not currently encrypted at rest; the team has flagged this as a backlog item.

Engineers access systems through role-based permissions. Multi-factor authentication is enforced for administrator accounts but is optional for regular engineers. The company's most recent third-party penetration test was completed eighteen months ago; a follow-up has not yet been scheduled.

4 AI AND AUTOMATED DECISIONS

The triage engine uses a large language model to suggest a likely cause and an urgency level for each user's symptoms. When the model flags a case as urgent, it is queued for a human clinician to review before any care recommendation is sent to the user; routine cases receive an automated explanation of the reasoning. The company keeps a registry of the three models running in production but has not yet performed a documented bias assessment on any of them.

5 VENDORS

MediFlow relies on three sub-processors: an email provider, a cloud analytics tool, and an LLM inference provider. Signed data processing agreements are in place with all three. The company does not currently publish a public list of these sub-processors.

6 INCIDENT HANDLING AND USER REQUESTS

The internal incident-response runbook states that confirmed data breaches are to be reported to the relevant authority "within five business days of confirmation." Users can request a copy of

their data through support, and the team typically fulfils export and access requests within 14 days. Deletion requests are honoured within 30 days, although encrypted database backups containing the deleted records are retained for a further 90 days before rotation.

7 GOVERNANCE

MediFlow maintains an internal record of its processing activities, reviewed quarterly by the engineering lead. It has not appointed a dedicated Data Protection Officer; privacy responsibilities are currently shared informally between the CTO and the head of legal.